

MOVA · Día 2 — Auditoría

Reglas mova_auth

acme-chile.cl · único validador de sesión

Tarea organizador: <index.html?tarea=mkof/02>

8 jul 2026 · GRUPO MAKING OF

Solo documentar y acordar — NO tocar código en servidor

Contexto — hallazgo Día 1

Inventario completado · login fragmentado

- Portal /mova/ → Google OAuth (no pasa por mova_auth).
- mova_auth/login.php → correo+clave (parcial, no gate del panel).
- mova/erp/ → contraseña local independiente.
- Ningún módulo M usa mova_auth como único validador.
- Antes de implementar (D3+), el equipo debe acordar las reglas por escrito.

Puente — para entender el hilo

De «Hallazgos D1» a «Mapa situación HOY»

PUENTE

El inventario listó cuatro formas distintas de «entrar». Antes de proponer reglas, visualizamos el problema: el usuario no sabe qué puerta usar y ningún módulo comparte la misma sesión.

Mapa conceptual

Inventario D1 → «login fragmentado» → 4 puertas distintas

/mova/ (Google) mova_auth/login.php /mova/erp/ (clave) /axon/ (¿?)

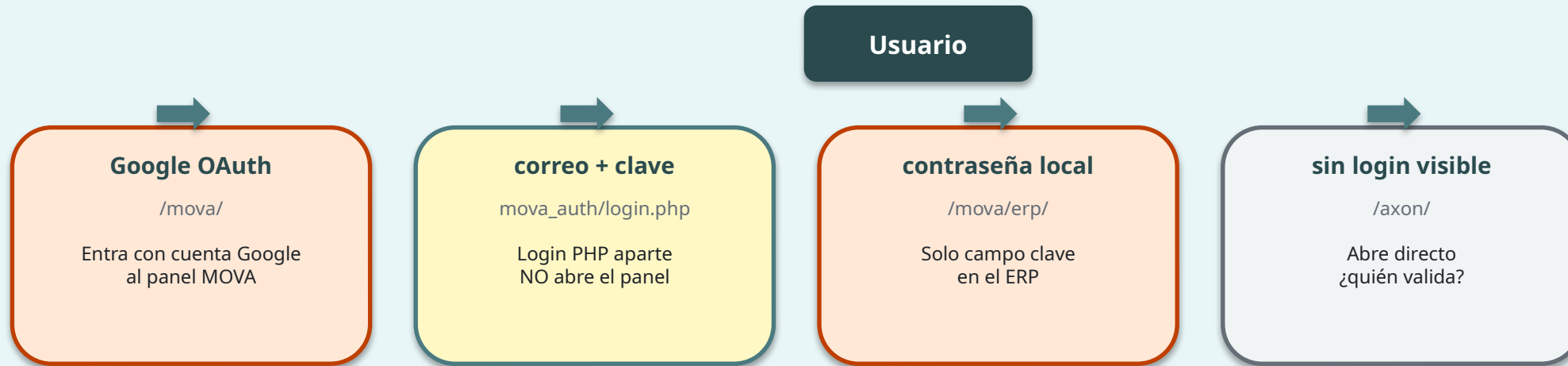
Conclusión: sin portero único, no hay seguridad ni experiencia coherente.

Siguiente slide: Mapa situación HOY

Mapa conceptual — situación HOY

¿Por qué necesitamos reglas?

El usuario no sabe por dónde «entrar». Cada módulo decidió su propio login.



En palabras simples:

- «Parcial, no gate del panel» = mova_auth/login.php existe, pero el panel /mova/ NO lo usa como entrada.
- «Login aparte» = el ERP tiene su propia pantalla de clave, distinta de todo lo demás.
- Conclusión D1: ningún módulo M tiene a mova_auth como único portero.

Puente — para entender el hilo

De «Mapa HOY» a «¿Qué es mova_auth?»

PUENTE

Vimos el caos actual. Ahora definimos el vocabulario del acuerdo: qué es mova_auth, qué hace guard.php y qué entendemos por «módulo M» — para que todos hablen lo mismo.

Mapa conceptual

Problema (varias puertas) → Solución propuesta: UN recepcionista

mova_auth = carpeta portero | guard.php = guardia en cada módulo | M = app interna MOVA

Siguiente slide: ¿Qué es mova_auth?

¿Qué es mova_auth?

Glosario para no técnicos

mova_auth

Carpeta en el servidor:
public_html/acme-chile.cl/mova_auth
/
Es el «portero» que debería validar a todos antes de entrar a apps MOVA.

login.php

Pantalla donde el usuario escribe correo y clave (o Google en el diseño futuro).
Hoy existe pero NO controla el acceso al panel /mova/.

guard.php

Archivo que cada módulo privado incluirá al inicio (futuro).
Pregunta: «¿hay sesión?» — si no, manda al login.

Módulo M

Cualquier app interna MOVA: portal, ERP, AXON, RRHH, facturas bajo /mova/, etc.

Analogía del edificio

Hoy: cada oficina (módulo) tiene su propia cerradura.

Objetivo: un solo recepcionista (mova_auth) en la entrada. Si no pasaste por recepción, ninguna oficina te abre.

Puente — para entender el hilo

De «Glosario» a «Regla de oro»

PUENTE

Con los términos claros, pasamos a la regla que el equipo debe acordar por escrito. Es la «constitución» del acceso: una sola frase que decide quién entra y quién no.

Mapa conceptual

Analogía edificio → Regla escrita → 5 reglas operativas numeradas

Si no pasaste por mova_auth con sesión válida → ningún módulo M te abre.

Siguiente slide: Regla de oro

Regla de oro

Propuesta para acuerdo del equipo

**Si el usuario no pasó por mova_auth con sesión válida,
no entra a ningún módulo M.**

1. Todo módulo privado incluye guard.php al inicio.
2. Sesión PHP server-side — sin JWT en localStorage.
3. Sin sesión → redirect a /mova_auth/login.php?redirect=...
4. Tras login → vuelve al módulo pedido.
5. Sin logins paralelos por módulo (salvo excepciones documentadas).

mova_auth = única puerta

Regla de oro — explicada paso a paso

Qué significa cada punto en la práctica

1 · guard.php

Como un guardia en la puerta de cada módulo.
Antes de mostrar contenido, verifica: «¿ya te autenticaste en mova_auth?»

2 · Sesión en servidor

La «credencial» vive en el servidor PHP, no en el navegador.
No guardamos tokens en localStorage (más seguro).

3 · Redirect al login

Si no hay sesión → pantalla login.php con parámetro redirect.
Ej: querías /mova/erp/ → tras login vuelves ahí.

4 · Vuelta al módulo

El usuario no pierde su destino. Entra una vez y llega donde iba.

5 · Sin logins paralelos

Se acaban las pantallas de Google sueltas, claves ERP aparte, etc.
Solo mova_auth (salvo excepciones escritas).

Puente — para entender el hilo

De «Regla de oro» a «Flujo OBJETIVO»

PUENTE

La regla en papel se traduce en un recorrido concreto. Este mapa muestra qué pasa cuando un usuario pide un módulo: guard verifica, login si hace falta, y vuelta al destino.

Mapa conceptual

Usuario → módulo → guard.php → ¿sesión? → Sí: entra | No: login.php?redirect= → vuelve

Siguiente slide: Flujo OBJETIVO

Mapa conceptual — flujo OBJETIVO

Cómo debería funcionar (diseño acordado)



Con sesión válida

guard.php deja pasar.
El módulo carga normal.
La cookie HttpOnly viaja sola
(sin que el usuario haga nada).

Sin sesión

guard.php redirige a login.
El usuario NO ve contenido privado.
Tras autenticarse, regresa
al módulo que pidió.

Clave: el módulo nunca decide solo quién entra — solo pregunta a mova_auth vía guard.php.

Puente — para entender el hilo

De «Flujo objetivo» a «Tabla de módulos»

PUENTE

El flujo aplica a apps concretas. La tabla del inventario D1 dice, módulo por módulo, quién debe pasar por mova_auth y cuál es la excepción documentada.

Mapa conceptual

Diseño genérico (guard + login) → Inventario real: Portal, ERP, AXON, RRHH, Documentos...

Siguiente slide: Tabla de módulos

¿Quién debe pasar por mova_auth?

Basado en inventario D1

Módulo	URL	Auth hoy	¿mova_auth?	Notas
Portal MOVA	/mova/	Google OAuth	Sí	Hoy no pasa
mova_auth	/mova_auth/	PHP correo+clave	Es el gate	Parcial
MOVA ERP	/mova/erp/	Contraseña local	Sí	Login aparte
AXON	/axon/	Sin login visible	Sí	Validar D5
RRHH	/rrhh/	403 Forbidden	Sí	Sin acceso público
Documentos	/documentos/	Público	No	Excepción

Submódulos bajo /mova/ (facturas, oc, agencia...) heredan la misma regla: deben pasar por mova_auth.

Tabla explicada — fila por fila

Para compartir con quien no vio el inventario D1

Portal MOVA	Hoy entra con Google. En el diseño nuevo debe pasar por mova_auth primero.
mova_auth	Es el portero. Hoy es «parcial» porque existe pero no controla todo.
MOVA ERP	Hoy tiene clave propia. Debe unificarse: misma sesión que el resto.
AXON	Abre sin login visible. Hay que definir validación (tarea D5).
RRHH	403 en servidor. Privado — debe pasar por mova_auth cuando se habilite.
Documentos	Público a propósito. EXCEPCIÓN — no necesita mova_auth.

Lectura rápida: verde=Sí debe pasar · violeta=es el gate · naranja=excepción pública

Puente — para entender el hilo

De «Tabla módulos» a «Excepciones públicas»

PUENTE

No todo el sitio es privado. Hay rutas que deben quedar abiertas (playbooks, assets, login mismo). También listamos lo prohibido después del acuerdo.

Mapa conceptual

DENTRO (módulos M) ← mova_auth → AFUERA (público / API validate)

Prohibido: Google suelto en módulo · JWT en localStorage · logins duplicados

Siguiente slide: Excepciones públicas

Excepciones y contenido público

No requieren mova_auth

/documentos/

Playbooks HTML públicos (auditoria_mova.html, etc.)

Assets estáticos

CSS, JS, imágenes sin datos sensibles

login.php

Página de entrada — no se protege con guard

logout.php

Cierre de sesión

validate.php

API JSON 200/401 para AJAX

Prohibido post-acuerdo: Google OAuth directo en módulo · JWT en localStorage · logins duplicados por módulo.

Mapa — ¿Qué está adentro y afuera?

Dentro del edificio vs calle pública

DENTRO — requiere mova_auth

/mova/ y submódulos

/mova/erp/

/axon/

/rrhh/

Todo módulo M privado

mova_auth

AFUERA — público / excepción

/documentos/ playbooks

CSS · JS · imágenes

login.php (entrada)

logout.php

validate.php API

Prohibido: poner Google OAuth o JWT dentro de un módulo «adentro» sin pasar por el portero.

Puente — para entender el hilo

De «Excepciones» a «Antes vs después»

PUENTE

Cerramos con un resumen visual del cambio acordado. Importante: hoy solo documentamos; la implementación en servidor empieza en Día 3+.

Mapa conceptual

ANTES: 4 logins · sesiones sueltas → DESPUÉS: 1 login · guard.php · cookie HttpOnly

Siguiente slide: Antes vs después

Antes vs después (resumen visual)

Lo que acordamos cambiar

ANTES (Día 1)

Google en /mova/

Clave suelta en ERP

mova_auth/login.php aislado

Sin portero único



DESPUÉS (acuerdo D2)

Un solo login en mova_auth

Sesión PHP + cookie HttpOnly

guard.php en cada módulo

Sin JWT en navegador

**Importante: «después» es el diseño acordado en auditoría.
La implementación en servidor empieza en Día 3+. Hoy solo firmamos las reglas.**

Checklist cierre Día 2

Compartir con equipo técnico

- ☐ Regla de oro acordada con equipo técnico
- ☐ Tabla de módulos revisada
- ☐ Excepciones públicas confirmadas
- ☐ Documento compartido (PDF/PPT)
- ☐ Tarea mkof/02 marcada completada

Pendiente: acuerdo formal (correo/acta) · Responsable: _____ · Fecha: _____

Próximo: Día 3 — Carpetas y archivos núcleo · mkof/03